

## Task 4 RACI Accountability Matrix (20 marks)

### 1. TechGlobal RACI Accountability Matrix

- **A = Accountable**
- **R = Responsible**
- **C = Consulted**
- **I = Informed**

| Activity                         | Board | CEO | CISO | CRO | Legal/ compliance | Finance | HR | IT |
|----------------------------------|-------|-----|------|-----|-------------------|---------|----|----|
| Cybersecurity strategy approval  | A     | A   | R    | C   | C                 | C       | I  | C  |
| Security policy approval         | I     | A   | R    | C   | C                 | I       | C  | C  |
| Enterprise cyber-risk assessment | I     | I   | R    | A   | C                 | I       | I  | C  |
| Risk acceptance                  | A     | A   | C    | R   | C                 | C       | I  | C  |
| Accept cybersecurity risks       | A     | A   | C    | R   | C                 | C       | I  | C  |
| Security budget approval         | C     | A   | C    | C   | I                 | R       | I  | C  |
| Security architecture approval   | I     | I   | A    | I   | C                 | I       | I  | I  |
| Third-party security review      | I     | I   | A    | C   | C                 | I       | I  | R  |
| Access governance                | I     | I   | A    | C   | C                 | I       | R  | R  |
| incident response governance     | I     | A   | R    | C   | C                 | I       | C  | R  |

|                                  |   |   |   |   |   |   |   |   |
|----------------------------------|---|---|---|---|---|---|---|---|
| Material incident escalation     | A | A | R | C | C | I | I | C |
| Regulatory notification decision | I | A | C | C | R | I | I | C |
| Security awareness programme     | I | A | R | I | C | I | R | C |

|                                           |   |   |   |   |   |   |   |   |
|-------------------------------------------|---|---|---|---|---|---|---|---|
| Vulnerability remediation oversight       | I | I | A | C | I | I | I | R |
| Business continuity / recovery governance | C | A | C | R | C | C | C | R |
| Board cyber-risk reporting                | A | C | R | C | C | I | I | I |

## 2. RACI Implementation Guide

### Using the RACI Matrix During Planning

Before starting a cybersecurity initiative, managers should review the RACI matrix to identify:

- The Accountable owner (A) who has final decision authority.
- The Responsible teams (R) who will perform the work.
- The Consulted stakeholders (C) who must provide specialist input.
- The Informed stakeholders (I) who require visibility.

Project plans should include the relevant accountable owner before activities begin. No major security initiative should proceed without a clearly assigned accountable role.

Example:

For a new cloud application deployment:

- IT is Responsible for technical implementation.
- CISO is Accountable for security architecture approval.
- Legal and Risk are Consulted.
- Business owners are Informed.

### Using the RACI Matrix During Approvals

Managers should use the matrix to ensure decisions are reviewed by the appropriate authority.

Approval processes should follow these principles:

- Accountable roles approve decisions involving risk, investment or business impact.
- Responsible teams provide evidence that requirements have been implemented.
- Consulted teams ensure regulatory, financial and operational considerations are addressed.
- Informed stakeholders receive updates for awareness and coordination.

This prevents situations where operational teams approve risks they do not own.

### Using the RACI Matrix During Cyber Incidents

During security incidents, the matrix provides a clear escalation structure.

Example of incident workflow:

| Stage                 | Accountable role         |
|-----------------------|--------------------------|
| Incident detection    | Security Operations / IT |
| Regulatory assessment | Compliance               |
| Risk decision         | Executive                |
| Board communication   | CISO,CEO                 |

#### RACI Governance Principles

1. Every critical activity must have one clearly identified accountable owner.
2. Responsibility should remain with the team performing the work.
3. Consultation should happen before decisions are made, not after.
4. Risk ownership should remain with the business owner, not only the security team.
5. The RACI matrix should be reviewed annually or after major organisational changes.